RA7-P1 Normativa de ciberseguretat



Roger Lesti Rodríguez
Marc Castro Linares
21-09-2026
ASIXc2A

EXERCICI 1

CAS 1: "Un ajuntament català perd les dades de ciutadans després d'un ciberatac"

A. **Fet real:**

Segons el link l'Ajuntament de Barcelona havia patit un ciberatac al portal web del Consell d'Habitatge que ha exposat les dades personals com (DNI, dates de naixement, telèfons, correus i codis postals) dels usuaris inscrits a la Borsa d'Habitatge de Lloguer entre el 2014 i el 2018.

Després de detectar la intrusió, el consistori va notificar l'incident a l'Autoritat Catalana de Protecció de Dades, va contenir l'atac traslladant l'aplicació a un servidor net i va contactar amb els afectats per oferir-los vies de suport i demanar-los que extremin les precaucions davant de possibles fraus.

En aquest cas, els ciberdelinqüents no van fer una petició de rescat ni van extorsionar l'Ajuntament de Barcelona, només van robar les dades i ja.

Font d'informació:
https://www.totbarcelona.cat/es/sociedad/un-ciberataque-expone-datos-de-la-bolsa-de-vivienda-de-alquiler-de-barcelona-690136/

B. **Llei aplicable**

- Reglamento General de Protección de Datos (RGPD) - Reglamento (UE) 2016/679: Artículos 32 (Seguridad del tratamiento) y 33 (Notificación de brechas de seguridad). Link: BOE - RGPD (UE 2016/679)

- **Ley Orgánica 3/2018 (LOPDGDD):** Adaptación del RGPD al marco español. https://www.boe.es/buscar/act.php?id=BOE-A-2018-16673&utm_source=gemini

Motiu: El RGPD exigeix que les institucions protegeixin les dades amb mesures de seguretat robustes. En patir una filtració de la base de dades de ciutadans, l'administració vulnera el deure de custòdia i la confidencialitat de les dades sensibles (noms, DNI, ingressos, dades de lloguer).

- **Código Penal Español (Ley Orgánica 10/1995):** Artículos 197 bis (Acceso no autorizado / Hacking) y 264 (Daños informáticos y sabotaje). https://www.boe.es/buscar/act.php?id=BOE-A-1995-25444&utm_source=gemini

- **Esquema Nacional de Seguridad (ENS) - Real Decreto 311/2022:** Obligatorio para administraciones públicas. https://www.boe.es/buscar/act.php?id=BOE-A-2022-7191&utm_source=gemini

Motiu: Les administracions públiques catalanes estan obligades per llei a implantar uns mínims de seguretat tècnica estàndard. En permetre una bretxa a l'aplicació web, es van incomplir les directrius mínimes de mitigació de vulnerabilitats exigides per l'Agència de Ciberseguretat de Catalunya i l'ENS.

C. Pena aplicable

Els atacants tenen penes de presó de 6 mesos a 2 anys per accés no autoritzat. Segons **Art. 197 bis CP** i Penas de prisión de 2 a 5 años si se afectan servicios esenciales o infraestructuras públicas per **Art. 264 y 264 bis CP.**

El Codi Penal imposa penes de presó perquè la intrusió vulnera el dret constitucional a la intimitat. S'aplica la pena a la seva franja més alta (2 a 5 anys) perquè la filtració afecta una gran quantitat de persones i les dades es van publicar amb ànim de lucre (per vendre'ls a la Dark Web).

Art.197bisCP
https://www.conceptosjuridicos.com/articulos/codigo-penal-articulo-197-bis/
Art. 264
https://www.conceptosjuridicos.com/articulos/codigo-penal-articulo-264/
Art. 264 bis CP
https://www.conceptosjuridicos.com/articulos/codigo-penal-articulo-264-bis/

D. Institució

Normativa infringida:

- Llei 15/2017, del 25 de juliol, de l'Agència de Ciberseguretat de Catalunya.
- Política de Ciberseguretat de la Generalitat (Acord GOV/145/2021) i Marc Normatiu de Seguretat de la Informació (MNSI).
- Llei 19/2014, de transparència, accés a la informació pública i bon govern.

Reguladora:

Una és Agència de Ciberseguretat de Catalunya (coordinació, resposta a incidents i supervisió). L'altre autoritat Catalana de Protecció de Dades (organisme sancionador/percebuts a l'àmbit públic de Catalunya).

Sancions

Les administracions públiques en aquest cas l'Ajuntaments sembla que no pateixen multes coercitives econòmiques a Espanya segons l'art. 77 de la LOPDGDD, sinó advertiments formals, requeriments obligatoris de correcció de mesures de seguretat, expedient disciplinari als responsables tècnics/polítics i publicació de l'acord sancionador al DOGC.

Roger Lesti Rodríguez
Marc Castro Linares
21-09-2026
ASIXc2A

CAS 2: "Una empresa privada envia correus comercials sense consentiment"

A. Fet real:

L'Agència Espanyola de Protecció de Dades ha sancionat amb 2.000 euros Tech Talents per enviar un correu publicitari no sol·licitat, vulnerant la Llei de Serveis de la Societat de la Informació. La multa es va imposar després que l'afectat intentés donar-se de baixa dues vegades sense èxit a través del web de l'empresa, que arribava a advertir que tramitar la baixa podia trigar fins a un any.

FONT:
https://www.economistjurist.es/actualidad-juridica/sancion-de-2-000-euros-por-enviar-un-correo-publicitario-no-deseado/

B. Llei aplicable (links)

Unión Europea: RGPD (UE 2016/679) - Art. 6: Exige base legal (consentimiento explícito) para tratar datos personales. Link: https://www.boe.es/doue/2016/119/L00001-00088.pdf

Estatal: LSSI-CE (Ley 34/2002) - Art. 21: Prohíbe enviar comunicaciones comerciales por correo electrónico sin autorización previa del destinatario.
https://www.boe.es/buscar/act.php?id=BOE-A-2002-13758

C. Pena aplicable

Sanción administrativa (Art. 38 y 39 de la LSSI-CE):

Multas de hasta **30.000 €** para infracciones leves (envío puntual o a pocos usuarios sin permiso).

Multas de **30.001 € a 150.000 €** para infracciones graves (envíos masivos y reiterados).

https://www.boe.es/buscar/doc.php?id=BOE-A-2002-13758

D. Institució

Institució: Com que és empresa privada llavors s'ocupa l'Agència Espanyola de Protecció de Dades.

Normativa: Aplica directamente la LSSI-CE (Ley 34/2002) y la LOPDGDD (Ley Orgánica 3/2018). *(La autoridad autonómica APDCAT supervisa únicamente el sector público catalán, no el ámbito privado)*.

Roger Lesti Rodríguez
Marc Castro Linares
21-09-2026
ASIXc2A

CAS 3: "Una escola no aplica protocols de seguretat a la seva xarxa Wi-Fi"

A. **Fet real:**

En el centre educatiu Holy Mary Catholic School de Madrid (Expedient AEPD PS-00321-2023 / Sanció reconeguda). El centre va desplegar la xarxa, les eines digitals i l'accés sense fils a Internet de les aules per als alumnes menors d'edat sense implementar els protocols de seguretat, filtrat ni xifratge requerits, ni realitzar la corresponent Avaluació d'Impacte en Protecció de Dades (AIPD). Això va permetre que els menors tinguessin un accés a la xarxa sense límit ni control de seguretat, posant en risc la privacitat i les dades personals dels alumnes. L'AEPD va declarar la manca de mesures tècniques i organitzatives de seguretat en l'entorn digital de l'escola.

https://confilegal.com/20260415-digitalizar-el-aula-sin-garantias-en-proteccion-de-datos-cuesta-12-000-euros-a-un-colegio-de-madrid

B. **Llei aplicable**

Normativa Europea (Rang superior):

- **Reglament General de Protecció de Dades (RGPD) (UE 2016/679) - Article 32:** Obliga al centre educatiu a implementar mesures tècniques i organitzatives de seguretat adients (com ara la configuració segura de xarxes Wi-Fi, xifratge i control d'accessos) per mantenir la confidencialitat de les dades dels alumnes.
- **RGPD (UE 2016/679) - Article 35:** Obligació de realitzar una avaluació d'impacte en la seguretat abans d'implantar tecnologies d'accés a xarxa en entorns amb menors.

  https://www.boe.es/buscar/doc.php?id=DOUE-L-2016-80807

Normativa Estatal (Espanyola):

- **Llei Orgànica 3/2018 (LOPDGDD) - Article 84:** Regula la protecció dels menors a Internet i l'obligació dels centres de garantir la seguretat en l'accés digital i xarxes del centre educatiu.
- **Esquema Nacional de Seguretat (ENS) (Reial Decret 311/2022):** Aplica directrius de seguretat per a comunicacions sense fils i sistemes d'informació de l'entorn educatiu.

  https://www.boe.es/buscar/act.php?id=BOE-A-2018-16673

Normativa Autonòmica (Catalunya):

- **Llei 15/2017, de 25 de juliol, de l'Agència de Ciberseguretat de Catalunya:** Estableix el marc de supervisió i protecció de xarxes i infraestructures digitals a Catalunya.

  https://www.boe.es/buscar/doc.php?id=BOE-A-2017-9800

C. Pena aplicable

Sanció en l'àmbit d'una escola privada (Via Administrativa - RGPD):

- Segons l'Article 83.4 del RGPD, es poden imposar multes d'un màxim de 10.000.000 d'euros o del 2% del volum de negoci anual global de l'entitat.

  https://eur-lex.europa.eu/legal-content/CA/TXT/?uri=CELEX:32016R0679

  https://www.boe.es/buscar/doc.php?id=DOUE-L-2016-80807

- En el cas real de l'escola sancionada per la AEPD, la multa inicial sumava 20.000 euros i es va reduir a 12.000 euros pel pagament voluntari i reconeixement de responsabilitat del centre.

Sanció en l'àmbit d'una escola pública (Administració pública / Generalitat):

- D'acord amb l'Article 77 de la LOPDGDD, les entitats públiques no reben multes econòmiques, sinó una sanció d'apercebiment públic, l'obertura d'un expedient disciplinari i el requeriment formal de corregir la seguretat de la xarxa Wi-Fi de manera immediata.

  https://www.boe.es/buscar/act.php?id=BOE-A-2018-16673

D. Institució

En l'àmbit de Catalunya, el compliment es divideix segons la titularitat del centre. Pel que fa a l'organització o institució reguladora a Catalunya, l'Autoritat Catalana de Protecció de Dades (APDCAT) és competent per auditar i sancionar el compliment de la seguretat i la protecció de dades en les escoles públiques i entitats dependents de la Generalitat o ajuntaments a Catalunya, mentre que l'Agència de Ciberseguretat de Catalunya (ACC) és l'encarregada de coordinar els protocols de seguretat digital i l'assistència davant vulnerabilitats en la xarxa del sector públic educatiu català. Respecte a la normativa catalana infringida segons el document de suport, s'incompleix la Llei 15/2017, de 25 de juliol, de l'Agència de Ciberseguretat de Catalunya pel que fa al deure de protecció de les xarxes públiques i comunicacions, així com el Marc Normatiu de Seguretat de la Informació (MNSI) en no complir els estàndards mínims de seguretat i xifratge en punts d'accés Wi-Fi i entorns d'aprenentatge digital establerts per la Generalitat de Catalunya. Quant a les sancions i multes a Catalunya, l'APDCAT o l'ACC emeten apercebiments formals a la direcció del centre o al Departament d'Educació, ordenant l'adopció de mesures tècniques immediates per xifrar i aïllar la xarxa Wi-Fi en un termini determinat, així com possibles expedients disciplinaris als responsables si es tracta de negligència en un centre públic.

CAS 5: “Una plataforma digital, d’una coneguda xarxa social d’intercanvi d’imatges i de videos, no aplica normes bàsiques de ciberseguretat i uns ciberdelinquents tenen accés a les dades de la seva base de dades d’usuaris, roben aquestes dades i les venen (exposen públicament) a la Dark web”.

A. **Fet real:**

Ciberatac a la plataforma comercial Décimas (expedient de la AEPD EXP202408867). Uns ciberdelinqüents van aprofitar una vulnerabilitat de tipus Injecció SQL al seu lloc web per accedir directament a la base de dades i extreure la informació de més de 331.000 clients (DNI, correus electrònics, data de naixement i gènere). Posteriorment, aquestes dades van ser filtrades, exposade a la Dark Web. La mateixa empresa no va detectar la bretxa, sinó que va ser l'INCIBE qui va donar l'avís en trobar la informació a la Dark Web.

https://forlopd.es/decimas-sancionada-con-120-000-euros-por-una-brecha-de-seguridad-que-afecto-a-mas-de-331-000-clientes/

https://confilegal.com/20260523-decimas-sancionada-con-120-000-euros-por-una-brecha-de-seguridad-que-expuso-datos-de-331-000-clientes/

B. **Llei aplicable**

Normativa Europea (Rang superior):

- **Reglament General de Protecció de Dades (RGPD) (UE 2016/679) - Article 32:** Regula el tractament de dades personals i exigeix a la plataforma establir normes i mesures tècniques estrictes de seguretat en la custòdia.
- **RGPD (UE 2016/679) - Articles 33 i 34:** Obliga la plataforma a notificar la bretxa de seguretat a l'autoritat de control en un termini màxim de 72 hores i comunicar-ho als usuaris afectats.

  https://www.boe.es/buscar/doc.php?id=DOUE-L-2016-80807

- **Directiva NIS2 (UE 2022/2555):** Directiva que millora la ciberseguretat dels serveis digitals i imposa l'obligació d'adoptar mesures de gestió de riscos i notificació d'incidents greus.

  https://www.boe.es/buscar/doc.php?id=DOUE-L-2022-81985

Normativa Estatal (Espanyola):

- **Llei Orgànica de Protecció de Dades Personals i Garantia dels Drets Digitals (LOPDGDD) (Llei Orgànica 3/2018):** Adapta el RGPD a Espanya i fixa les sancions per negligència en la protecció de les dades.

  https://www.boe.es/buscar/act.php?id=BOE-A-2018-16673

- **Codi Penal Espanyol (Llei Orgànica 10/1995) - Article 197 bis 2:** Penalitza l'accés il·legítim i hackeig de bases de dades per part dels ciberdelinqüents.
- **Codi Penal Espanyol - Article 197.2 i 197.3:** Sanciona el robatori, la revelació, difusió i venda de dades personals contingudes en fitxers informàtics a tercers o a la Dark Web.

  https://www.boe.es/buscar/act.php?id=BOE-A-1995-25444

- **Reial Decret-Llei 12/2018:** Transposició de la directiva de seguretat de xarxes per a la notificació d'incidents greus de ciberseguretat.

  https://www.boe.es/buscar/doc.php?id=DOUE-L-2022-81985

C. **Pena aplicable**

Penes als ciberdelinqüents (Via Penal):

- Pena de presó de 2 a 5 anys per exfiltrar, difondre, cedir o vendre a tercers (Dark Web) dades d'caràcter personal robades d'una base de dades (Art. 197.3 del Codi Penal).

  Llei Orgànica 10/1995, de 23 de novembre, del Codi Penal (Boletín Oficial del Estado núm. 281, de 24 de novembre de 1995).

Sancions a la plataforma digital / empresa (Via Administrativa):

- D'acord amb l'Article 83 del RGPD, es poden imposar multes administratives d'fins a 20 milions d'euros o el 4% del volum de negoci global anual de l'empresa de l'exercici financer anterior.

  Reglament (UE) 2016/679 del Parlament Europeu i del Consell, de 27 d'abril de 2016 (Diari Oficial de la Unió Europea L 119/1, de 4 de maig de 2016).

- En el cas real de Décimas, l'Agència Espanyola de Protecció de Dades va imposar una sanció de 120.000 euros per falta de mesures de seguretat i monitorització de vulnerabilitats.

  Llei Orgànica 3/2018, de 5 de desembre, de Protecció de Dades Personals i garantia dels drets digitals (Boletín Oficial del Estado núm. 294, de 6 de desembre de 2018).

D. Institució

En tractar-se d'una empresa privada d'àmbit estatal, l'organisme competent és l'AEPD (estatal) i la normativa aplicada és la LOPDGDD i el RGPD europeu (no la normativa catalana).
Si el ciberatac de la base de dades hagués afectat una institució pública catalana (com un ajuntament, un hospital de la xarxa pública o la mateixa Generalitat), o bé una xarxa social/plataforma impulsada per la mateixa administració catalana:

- Organització reguladora: APDCAT (Autoritat Catalana de Protecció de Dades) i l'ACC (Agència de Ciberseguretat de Catalunya).
- Normativa catalana infringida: La Llei 15/2017, de 25 de juliol, de l'Agència de Ciberseguretat de Catalunya i el Marc Normatiu de Seguretat de la Informació (MNSI) de l'ACC.
- Sancions a Catalunya: L'APDCAT pot imposar des d'apercebiments públics i requeriments d'esmena obligatoris fins a sancions econòmiques segons la gravetat de la negligència.

EXERCICI 2 - CONCLUSIONS

Roger Lesti:

M'ha permès prendre la vulnerabilitat dels sistemes reals i de l'impacte que té les negligències tècniques sobre la privadesa de les persones. He après alguna estratègia de defensa que passa per l'aplicació rigorosa de protocols de seguretat des del primer moment, la monitorització constant de vulnerabilitats i una gestió ràpida i transparent en la notificació d'incidents. També he après una mica més dels marcs normatius i d'alguns organismes reguladors.

Marc Castro:

Aquesta activitat m'ha permès entendre que la ciberseguretat és una responsabilitat directa sobre els drets digitals de la ciutadania. Les lleis europees i estatals no solament castiguen els ciberdelinqüents, sinó que penalitzen les negligències de les organitzacions en la custòdia de la informació. Com a futurs administradors de sistemes, tenim la responsabilitat ètica d'implantar la seguretat per defecte, ja que qualsevol bretxa tècnica té un impacte real en la vida i la privadesa de les persones.